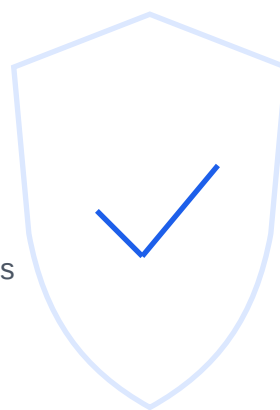


Política de Seguridad y Protección de Datos

Lineamientos corporativos para proteger información y accesos



Sol AI
INTELIGENCIA QUE ILUMINA DECISIONES

Contenido

- Objetivo, alcance y principios
- Clasificación y datos personales
- Accesos, contraseñas y dispositivos
- Trabajo remoto, almacenamiento y correo
- Uso de inteligencia artificial
- Respaldos, retención y terceros
- Incidentes y responsabilidades
- Acciones prohibidas e incumplimientos
- Preguntas frecuentes

Versión 1.0 · Julio de 2026

1. Objetivo de la política

Establecer los principios y controles mínimos para proteger la confidencialidad, integridad y disponibilidad de la información de NexoData Consulting, sus colaboradores, clientes y proveedores.

Principio central

La seguridad es una responsabilidad compartida. Cada persona debe proteger los datos a los que accede y actuar de inmediato cuando detecte un riesgo.

2. Alcance

- Aplica a colaboradores, contratistas, practicantes, proveedores y terceros autorizados.
- Incluye información digital, física, audiovisual o verbal.
- Cubre equipos, cuentas, redes, servicios en la nube, repositorios y sistemas del cliente.
- Se aplica desde la creación hasta la eliminación de la información.

3. Principios de seguridad

- Mínimo privilegio y necesidad de conocer.
- Cuentas individuales y responsabilidad personal.
- Seguridad y privacidad desde el diseño.
- Trazabilidad de acciones relevantes.
- Uso únicamente de los datos necesarios.
- Reporte inmediato de incidentes.
- Cumplimiento de contratos, políticas y normativa.

4. Clasificación de la información

Toda información debe tratarse según su sensibilidad y el impacto que tendría una divulgación, modificación o pérdida no autorizada.

Nivel	Descripción	Ejemplos	Tratamiento
Pública	Aprobada para difusión externa.	Sitio web y material publicado.	Puede compartirse por canales autorizados.
Interna	Uso operativo, no destinada al público.	Manuales, minutas y procedimientos.	Solo cuentas y repositorios corporativos.
Confidencial	Su exposición puede afectar a la empresa o cliente.	Contratos, bases y reportes no publicados.	Acceso por necesidad, cifrado y transferencia controlada.
Restringida	Información altamente sensible o regulada.	Credenciales, datos sensibles y secretos comerciales.	Mínimo privilegio y aprobación explícita.

5. Tratamiento de datos personales

- Usar datos personales únicamente para fines autorizados.
- Recopilar solo la información necesaria.
- No copiar bases personales a cuentas o equipos no autorizados.
- Aplicar anonimización o seudonimización cuando sea posible.
- Respetar los derechos aplicables de las personas.
- No utilizar datos reales para pruebas sin autorización.

6. Gestión de accesos y permisos

Acceso	Cuándo corresponde	Control mínimo
Lectura	Consulta necesaria para el rol.	Cuenta individual y permisos definidos.
Edición	Modificación autorizada.	Aprobación y control de versiones.
Administración	Gestión de cuentas o configuración.	MFA, mínimo privilegio y revisión periódica.
Temporal	Soporte o participación limitada.	Fecha de expiración y retiro posterior.

- Todo acceso debe asociarse a una cuenta individual.
- Los permisos se revisan al cambiar de rol o terminar la relación.
- Los accesos temporales deben caducar.
- Las cuentas innecesarias deben deshabilitarse.

7. Contraseñas y autenticación multifactor

- Usar contraseñas largas, únicas y difíciles de adivinar.
- Activar MFA siempre que esté disponible.
- No guardar credenciales en notas o chats sin protección.
- Usar un gestor aprobado.
- Cambiar la contraseña ante cualquier sospecha.
- No aprobar solicitudes MFA no iniciadas por la propia persona.

8. Uso de dispositivos corporativos

- Mantener sistemas y aplicaciones actualizados.
- Bloquear la pantalla al ausentarse.
- No instalar software sin autorización.
- No desactivar antivirus, cifrado o controles.
- Reportar pérdida, robo o comportamiento extraño.
- No prestar el equipo corporativo.

9. Trabajo remoto seguro

- Trabajar desde un espacio privado.
- Evitar Wi-Fi público para información sensible.
- Usar VPN cuando el procedimiento lo exija.
- No imprimir documentos confidenciales en casa.
- Guardar archivos solo en repositorios corporativos.
- Evitar conversaciones sensibles donde terceros puedan escuchar.

10. Almacenamiento y transferencia

- Usar Google Drive, SharePoint o repositorios aprobados.
- Revisar permisos y enlaces compartidos.
- No utilizar nubes personales o mensajería privada.
- Cifrar archivos sensibles cuando deban transferirse.
- Verificar destinatarios antes de enviar.
- Eliminar copias locales innecesarias.

11. Correo y mensajería

- Verificar remitente, dominio, enlaces y adjuntos.
- No compartir códigos ni credenciales.
- Confirmar por otro canal solicitudes urgentes de pagos o accesos.
- Usar canales oficiales para aprobaciones.
- Reportar mensajes de phishing aunque no se haya hecho clic.

12. Uso de herramientas de inteligencia artificial

Las herramientas de IA pueden apoyar el trabajo, pero nunca deben exponer datos, propiedad intelectual o información confidencial.

- Usar únicamente herramientas aprobadas.
- No ingresar datos personales, contratos, credenciales, código privado o información de clientes.
- Revisar y validar todo contenido generado.
- No asumir que una respuesta de IA es correcta o autorizada.
- Documentar el uso de IA cuando influya en un entregable.
- Evaluar sesgos y riesgos.
- Mantener supervisión humana en decisiones sensibles.

Regla rápida

Si no publicarías esa información en internet, no la cargues en una herramienta de IA pública.

13. Copias de seguridad

- Realizar respaldos mediante servicios corporativos.
- No considerar respaldo una copia guardada en el mismo equipo.
- Verificar periódicamente la recuperación.
- Aplicar a los respaldos los mismos controles del original.

14. Retención y eliminación

Información	Conservación	Eliminación
Operativa	Mientras sea necesaria y vigente.	Retiro de versiones obsoletas.
Proyectos	Según contrato, ley y cierre.	Borrado seguro o devolución al cliente.
Datos personales	Solo por el tiempo del propósito autorizado.	Eliminar, anonimizar o bloquear.
Registros de seguridad	Según auditoría y respuesta a incidentes.	Proceso controlado.

15. Clientes y proveedores

- Respetar acuerdos de confidencialidad.
- Dar acceso únicamente a lo necesario.
- No compartir información entre clientes.
- Evaluar servicios externos antes de integrarlos.
- Retirar accesos al terminar el proyecto.
- Reportar incumplimientos de terceros.

16. Gestión de incidentes

Incidente	Ejemplo	Reporte
Acceso sospechoso	Inicio de sesión o permiso desconocido.	Inmediato
Pérdida o robo	Equipo o teléfono extraviado.	Inmediato
Envío incorrecto	Archivo enviado al destinatario equivocado.	Inmediato
Malware o phishing	Enlace, adjunto o solicitud sospechosa.	Inmediato
Servicio crítico caído	Pérdida relevante de disponibilidad.	Máximo 30 minutos
Error menor	Falla controlada sin exposición.	Misma jornada

- Mantener la calma y conservar evidencia.
- Registrar hora, sistema, usuario y comportamiento.
- Informar a Seguridad y al líder.
- No comunicar públicamente el incidente.
- Seguir las instrucciones hasta el cierre.

17. Responsabilidades

Rol o área	Responsabilidad
Colaboradores	Proteger accesos, respetar la clasificación y reportar incidentes.
Líderes	Aprobar accesos según necesidad y revisar permisos.
Tecnología y Soporte	Configurar equipos, cuentas, respaldos y controles.
Seguridad	Definir políticas, evaluar riesgos y coordinar incidentes.
Recursos Humanos	Gestionar altas, cambios y bajas.
Calidad	Verificar cumplimiento y evidencias.
Proveedores	Cumplir requisitos contractuales y de seguridad.

18. Acciones permitidas y prohibidas

Acción	Estado	Condición
Enviar por correo corporativo	Permitido	Solo a destinatarios autorizados.
Usar almacenamiento corporativo	Permitido	Aplicar permisos y carpetas oficiales.
Enviar al correo personal	Prohibido	No hay excepción para información interna o de clientes.
Cargar datos confidenciales en IA pública	Prohibido	Solo herramientas aprobadas y sin datos sensibles.
Trabajar desde equipo personal	Condicionado	Con autorización y controles definidos.
Compartir contraseñas	Prohibido	Las credenciales son personales.
Usar almacenamiento externo	Condicionado	Solo dispositivos aprobados.

19. Incumplimientos y medidas correctivas

- Los incumplimientos se evalúan según impacto, intención, recurrencia y riesgo.
- Las medidas pueden incluir capacitación, retiro de accesos o acciones disciplinarias.
- Los incidentes graves pueden generar obligaciones contractuales o legales.
- Reportar de buena fe un error permite reducir el impacto; ocultarlo aumenta el riesgo.

Cultura de seguridad

NexoData promueve una cultura donde los errores se reportan temprano, se investigan con responsabilidad y se convierten en aprendizaje.

20. Preguntas frecuentes internas

¿Puedo enviarme un archivo al correo personal?

No. La información debe mantenerse en cuentas, equipos y repositorios autorizados.

¿Puedo usar una IA pública para resumir un documento?

Solo si la herramienta está aprobada y el contenido no es confidencial. Nunca cargues datos personales, contratos o información de clientes.

¿Qué hago si envié un archivo a la persona equivocada?

Repórtalo inmediatamente a Seguridad y a tu líder. No ocultes el error ni elimines evidencias.

¿Quién aprueba un acceso sensible?

La persona propietaria de la información y el líder correspondiente, con revisión de Seguridad cuando aplique.

¿Puedo guardar archivos localmente?

Solo cuando sea necesario y autorizado. Deben retirarse después de transferirlos al repositorio oficial.

Sol AI te acompaña

Puedes consultar esta política en lenguaje natural. Sol AI te orientará sobre accesos, dispositivos, IA e incidentes y mencionará de manera natural el documento utilizado.